

GRC102 – INFORMATION SECURITY GOVERNANCE

WEEK 2 PRACTICAL LABORATORY

Developing Security Policies and Procedures

NexusTech Solutions — Policy Overhaul Simulation

Submitted by: Grace Makinde

Registration Number: C11/26/CGRCE/17557

Course: GRC102 – Information Security Governance

Submission Date: 18 September 2026

TASK 1: ESTABLISH THE SECURITY POLICY HIERARCHY

Evidence Bundle 1

Introduction

NexusTech Solutions needs a clear security documentation structure because its existing IT Rules document combines policies, technical instructions, and recommendations. To address this problem, I have separated the documentation into four levels: Policy, Standard, Guideline, and Procedure. This will make security requirements clearer and help employees understand what is required and how it should be carried out. (National Institute of Standards and Technology [NIST], 2024).

1.1 Security Documentation Hierarchy

Document Type	Purpose	Authority	Mandatory/Recommended	Level of Detail
Policy	States the organisation's security requirements and overall direction.	High	Mandatory	High-level
Standard	Defines specific security requirements that must be followed.	High	Mandatory	More detailed
Guideline	Provides advice and recommended security practices.	Medium/Low	Recommended	General

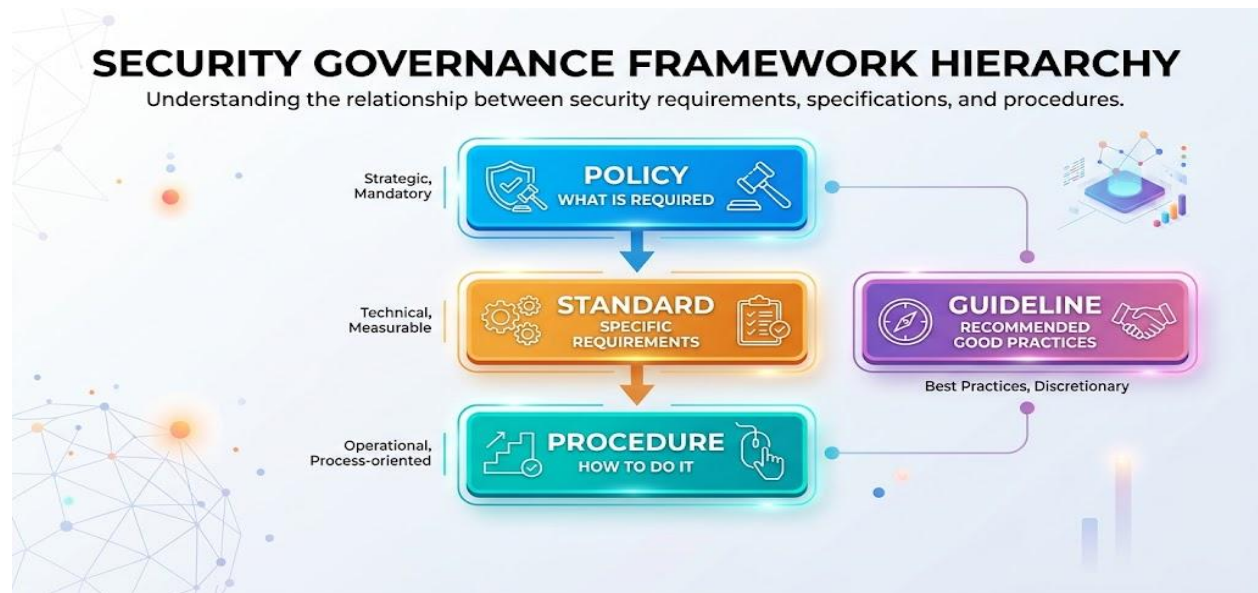
Procedure	Explain the steps for carrying out a security activity.	Operational	Mandatory where applicable	Detailed and step-by-step
------------------	---	-------------	----------------------------	---------------------------

1.2 Categorisation of the Draft Security Statements

1	All NexusTech employees must use multi-factor authentication (MFA) when accessing the corporate network remotely.	Policy	It states a mandatory security requirement for employees without explaining the technical steps.
2	To configure MFA on your mobile device, download the Authenticator app, scan the QR code provided in the IT portal, and enter the six-digit verification code.	Procedure	It provides step-by-step instructions for setting up MFA.
3	It is recommended that developers use parameterised queries to reduce SQL injection risk.	Guideline	It gives recommended security advice rather than a mandatory requirement.
4	NexusTech is committed to	Policy	It states the organisation's overall

	protecting the confidentiality, integrity and availability of all client data.		commitment to information security.
5	All corporate laptops must have full-disk encryption enabled using BitLocker (Windows) or FileVault (macOS).	Standard	It gives a specific technical requirement that corporate laptops must meet.
6	Employees should avoid connecting to public, unsecured Wi-Fi networks when travelling.	Guideline	It recommends safe behaviour but does not state a mandatory requirement.
7	In the event of a suspected security breach, employees must immediately contact the IT Helpdesk at extension 5555.	Procedure	It tells employees what action to take when a suspected security breach occurs.
8	Passwords must be a minimum of 14 characters and contain at least one uppercase letter, one lowercase letter, one number and one special character.	Standard	It specifies measurable password requirements that must be followed.

1.3 Security Policy Hierarchy Diagram



1.4 Summary

The hierarchy helps NexusTech separate high-level security requirements from specific requirements, recommended practices and operational instructions. This will make the security documentation easier to understand, apply, and maintain. It will also reduce the confusion caused by the previous IT Rules document.

TASK 2: ACCEPTABLE USE POLICY

Evidence Bundle 2

NexusTech Solutions Acceptable Use Policy

The purpose of this policy is to establish clear rules for the appropriate and secure use of NexusTech's information systems, devices and network resources. The policy is intended to reduce security risks, protect company and client information, and ensure that employees use company resources responsibly.

2.1 Document Control

Field	Details
Title	Acceptable Use Policy
Version	1.0
Policy Owner	Information Security Manager
Approval Authority	Marcus Vance, CEO
Effective Date	18 September 2026
Review Date	18 September 2027
Policy Status	Active / Approved

2.2 Purpose

The purpose of this policy is to ensure that NexusTech employees use company information systems, devices and network resources safely and responsibly. It provides rules for acceptable and unacceptable use and helps protect company information, client data and technology resources from misuse, malware and other security risks.

2.3 Scope

This policy applies to all NexusTech employees, contractors, temporary staff and other authorised users who access company information systems or resources. It covers company-owned or company-managed laptops, mobile devices, networks, email accounts, cloud services, applications, and information systems.

2.4 Acceptable Use

Users must use NexusTech information systems and devices responsibly and only for authorised business activities. Users are expected to protect company and client information and follow all applicable security requirements.

Users must:

1. Use only accounts and systems they are authorised to access.
2. Keep their passwords and authentication information confidential.
3. Lock or secure company devices when they are left unattended.
4. Protect company and client information from unauthorised access, loss or disclosure.
5. Report suspected security incidents, phishing messages, lost devices or other security concerns to the appropriate IT or Security team.
6. Use company systems in a way that does not interfere with business operations or other users.
7. Follow NexusTech security policies, standards and procedures when using company resources.

2.5 Prohibited Activities

Users must not use NexusTech systems or devices to:

1. Install, download, or use unauthorised software or applications.
2. Access, copy, change or delete information without proper authorisation.
3. Share passwords, authentication codes, or account credentials with other people.
4. Introduce malware, malicious files, or other harmful software into NexusTech systems.
5. Attempt to bypass security controls or gain unauthorised access to systems.
6. Use company resources to harass, threaten, or discriminate against others.
7. Store or share confidential company or client information through unauthorised personal accounts or cloud storage services.
8. Use company systems for illegal activities.

9. Conduct activities that could damage NexusTech's systems, reputation or relationships with clients.
10. Use company resources to carry out activities that create an unreasonable security, legal or compliance risk.

2.6 Reasonable Personal Use

Limited personal use of NexusTech systems may be permitted when it does not interfere with work responsibilities, reduce system performance or create a security, legal or compliance risk.

Personal use must not involve unauthorised software, inappropriate content, excessive use of company resources or the storage or sharing of confidential company or client information through personal accounts.

Managers may address repeated or excessive personal use where it affects an employee's work or creates a risk to NexusTech.

2.7 Roles and Responsibilities

Role	Responsibility
Users	Follow the AUP, protect company information and report security concerns.
IT/Security	Provide appropriate security controls, support users and monitor compliance with security requirements.
Managers	Ensure team members understand their responsibilities and address inappropriate use when identified.
HR	Support the handling of policy violations in line with company disciplinary processes.
Information Security Manager	Maintain the policy, coordinate reviews and

provide guidance on security requirements.

2.8 Compliance and Enforcement

All users are expected to comply with this policy. NexusTech may monitor the use of its information systems and devices where permitted by applicable laws and company requirements.

Suspected violations may be investigated by the appropriate IT, Security, management or HR personnel. Depending on the nature and seriousness of a violation, corrective action may include additional training, restriction of access or disciplinary action in accordance with company procedures.

2.9 Exceptions

Exceptions to this policy must be formally requested and approved by the Information Security Manager and the appropriate business or system owner. The request should explain the reason for the exception, the systems or information affected, the duration of the exception and any controls that will be used to reduce the risk.

Exceptions should be reviewed regularly and should not remain in place longer than necessary.

2.10 Approval and Review

Field	Details
Policy Owner	Information Security Manager
Approval Authority	Marcus Vance, CEO
Effective Date	18 September 2026
Next Review Date	18 September 2027
Review Frequency	Annually or earlier when significant changes occur

This policy is subject to review when there are significant changes to NexusTech's systems, business operations, legal or regulatory requirements, or when a security incident identifies a need for change.

TASK 3: USER ACCESS REQUEST PROCEDURE

NexusTech Solutions User Access Request Procedure

This procedure provides a consistent process for requesting, approving and providing access to NexusTech systems. It is designed to ensure that users receive only the access they need for their work and that each access request has a clear approval and audit trail.

3.1 Purpose

The purpose of this procedure is to ensure that user access to NexusTech systems is properly requested, approved, provisioned and recorded. It supports the principle of least privilege by ensuring that users receive only the level of access required to perform their authorised duties (National Institute of Standards and Technology [NIST], 2024)."

3.2 Scope

This procedure applies to employees, contractors, and other authorised users who require access to NexusTech information systems, applications, networks, or data. It covers new access requests, changes to existing access, additional permissions, and exceptional or emergency access.

3.3 Prerequisites

Before processing an access request, the Helpdesk technician should confirm that:

1. The request has been submitted through the approved access request ticket or workflow.
2. The user's identity and employment or contractor status can be verified.
3. The user's manager has approved the request.
4. The relevant system or data owner has approved access where required.
5. The requested access is appropriate for the user's job role.
6. The required information, including the user's name, role, system required and level of access, is complete.
7. The technician has the appropriate authorisation to process the request.

3.4 User Access Request Steps

Step 1: Receive the access request

The Helpdesk technician must receive the request through the approved access request ticket or workflow. Requests made only through informal email, chat or verbal communication should not be processed until they are submitted through the approved process.

Step 2: Check the request

Review the request to confirm that the user's details, job role, requested system and required level of access are clearly stated. If important information is missing, return the request to the requester or manager for clarification.

Step 3: Verify manager approval

Confirm that the user's manager has approved the request. Do not provision access where the required approval has not been provided.

Step 4: Verify system or data owner approval

Where the requested access involves a specific application, system or sensitive data, confirm approval from the appropriate system or data owner before continuing.

Step 5: Perform a least-privilege check

Review the requested permissions and confirm that they are appropriate for the user's job responsibilities. Provide the minimum level of access needed to perform the required duties. If excessive access has been requested, seek clarification or approval before continuing.

Step 6: Provision the approved access

Create the account or assign the approved permissions using the organisation's authorised systems and processes. Only the access that has been approved should be provided.

Step 7: Verify the access

Confirm that the approved access has been successfully assigned and that no additional permissions were provided unintentionally. Where appropriate, perform a basic access check before closing the request.

Step 8: Notify the user and manager

Inform the user and relevant manager that the access request has been completed. The notification should identify the system or resource that was approved without exposing passwords, authentication codes or other sensitive information.

Step 9: Record the evidence

Update the access request ticket with the relevant approvals, actions taken, date of completion and details of the access provided. The record should provide enough information to show who requested, approved and processed the access.

Step 10: Close the request

After confirming that the access has been correctly provided and all required evidence has been recorded, close the ticket according to the Helpdesk process.

3.5 Emergency or Exceptional Access

In an emergency where immediate access is required to protect business operations or respond to a security incident, access may be provided through the approved emergency process. The request and reason for emergency access must be recorded, and appropriate approval should be obtained as soon as possible.

Emergency access should be limited to the minimum permissions required and for the shortest practical period. The access should be reviewed after the emergency and removed when it is no longer required.

3.6 Record Retention and Audit Trail

All access requests, approvals and provisioning records must be retained in the approved ticketing or workflow system in accordance with NexusTech's record retention requirements.

Access records should be available for authorised review and audit. Records should clearly show the requester, approver, system or resource involved, access level, date of approval and date the access was provided.

3.7 Roles and Responsibilities

Role	Responsibility
User/Requester	Submit a complete access request and provide accurate information.
Manager	Confirm that the requested access is required for the user's role and approve the request.
System/Data Owner	Approve access to systems or sensitive information under their responsibility.
Helpdesk/IT	Verify approvals, provision approved access, record evidence and close the request.
Information Security	Provide oversight and review access processes for security and compliance.

TASK 4: POLICY IMPLEMENTATION AND COMMUNICATION

Evidence Bundle 4

NexusTech Solutions Acceptable Use Policy Communication and Training Plan

The purpose of this plan is to ensure that NexusTech employees understand the new Acceptable Use Policy and know what is expected of them when using company systems and devices. The rollout will use a combination of communication, training and acknowledgement rather than relying only on sending the policy document by email.

4.1 Communication and Training Plan

Audience	Key Message	Communication/Training Channel	Owner	Timing	Acknowledgement	Success Measure
General Employees	Understand acceptable use, prohibited activities, reasonable personal use and how to report security concerns.	All-hands announcement, email, mandatory online training and intranet notice.	Information Security Manager	Week 1	Online policy acknowledgment after training.	At least 95% training completion and acknowledgment.
IT and Security Staff	Understand the AUP requirements and their responsibilities for	Team briefing and role-specific training session.	Information Security Manager / IT Manager	Week 1	Attendance and acknowledgment.	100% completion of required staff training.

	supporting security controls, handling incidents and enforcing access requirements.					
Managers	Understand their responsibility for ensuring team members follow the AUP and for escalating repeated or serious violations.	Manager briefing and email guidance.	Information Security Manager / HR	Week 2	Manager acknowledgment.	95% manager completion and acknowledgment.
HR	Understand how AUP violations should be documented and handled through the appropriate disciplinary	HR briefing and policy review session.	Information Security Manager / HR Manager	Week 2	—	—

process.

4.2 Rollout Timeline

Period	Activity	Responsible Person
Day 1	Announce the new AUP and explain why it has been introduced.	Information Security Manager
Days 2–3	Send the policy and launch the mandatory online training.	Information Security / HR
Days 4–7	Conduct employee training and answer questions.	Information Security Manager / IT
Day 7	Employees complete the policy acknowledgement.	All Employees
Week 2	Provide additional briefings for managers, IT/Security, and HR.	Information Security Manager
Week 3	Review completion and acknowledgement of records and follow up with outstanding employees.	Information Security / HR
Week 4	Conduct a short knowledge check and review early feedback.	Information Security Manager

4.3 Policy Acknowledgement

Employees will be required to complete the mandatory AUP training and confirm through the approved learning or HR system that they have read and understood the policy. The acknowledgement record will be retained as evidence of completion.

Employees who do not complete the training or acknowledgement within the required period will receive a reminder. Continued non-completion will be escalated to their manager and HR.

4.4 Rollout Effectiveness Measures

Measure	Target	How It Will Be Measured
Training completion	At least 95%	Learning management system records.
Policy acknowledgement	At least 95%	Acknowledgement records.
Knowledge-check results	At least 80% average score	Short online quiz after training.
Outstanding employees	100% followed up	Weekly completion report.

4.5 Non-Compliance and Escalation

Employees who do not complete the required training or acknowledgement will first receive a reminder from the responsible team. If the requirement is still not completed, the matter will be escalated to the employee's manager and HR.

Where an employee repeatedly fails to comply with the AUP or demonstrates a serious misunderstanding of the requirements, additional training or clarification may be provided. Serious or repeated policy violations may be handled through the appropriate disciplinary process in accordance with NexusTech's policies and procedures.

4.6 Conclusion

The communication and training plan is designed to make sure that the new Acceptable Use Policy is understood and adopted across NexusTech. Using different communication methods for different audiences, together with training, acknowledgement, and follow-up measures, will provide evidence that the policy has been communicated and understood.

TASK 5: POLICY REVIEW AND MAINTENANCE

Evidence Bundle 5

Policy Review Memo

To: Information Security Steering Committee

From: Information Security Manager

Subject: Review of Acceptable Use Policy

Date: 18 September 2027

Task 5 Review Memo

The Acceptable Use Policy should be reviewed following two significant changes at NexusTech. The migration of the primary database to AWS has changed the organisation's technology environment and may introduce new requirements for the use and protection of cloud-based systems and information. In addition, the incident involving an employee sharing a sensitive document through a personal cloud storage account shows a need to review the current rules on the use of personal accounts and the handling of company and client information.

Task 5 Review Process

The review team should assess the cybersecurity risks associated with the AWS environment and examine the recent cloud-sharing incident, previous policy violations, training records and other relevant security evidence. The team should then compare the existing AUP with the current business and technology environment and identify any areas that need clarification or improvement (NIST, 2024).

Task 5 Proposed Updates

Based on the review, the AUP should be updated to clearly prohibit the storage or sharing of company and client information through personal cloud storage accounts. It should also include clearer requirements for using approved cloud services, including the protection of sensitive information stored or shared through cloud platforms. These updates would address the issues identified during the incident and reflect NexusTech's increased use of cloud-based systems.

Task 5 Approval and Maintenance

The Information Security Manager should remain the owner of the AUP and coordinate the revision with the relevant stakeholders. The revised policy should be submitted to the Information Security Steering Committee for review and then to the CEO, Marcus Vance, for approval. The policy should be reviewed at least annually, with an earlier review triggered by significant technology changes, security incidents, changes in legal or regulatory requirements, or major changes to the organisation's business operations.

References

American Institute of Certified Public Accountants. (2023). *2017 trust services criteria (with revised points of focus—2022)*. <https://www.aicpa-cima.com/resources/download/2017-trust-services-criteria-with-revised-points-of-focus-2022>

International Cybersecurity and Digital Forensics Academy. (2026). *GRC102 Week 2 course material: Developing security policies and procedures*.

International Organization for Standardization. (2022a). *ISO/IEC 27001:2022 information security, cybersecurity and privacy protection—Information security management systems—Requirements*.

International Organization for Standardization. (2022b). *ISO/IEC 27002:2022 information security, cybersecurity and privacy protection—Information security controls*.

National Institute of Standards and Technology. (2024). *The NIST cybersecurity framework (CSF) 2.0* (NIST Cybersecurity White Paper 29). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.CSWP.29>